

Security+ 4.6 · Password Security

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.6** — Password Security (6:22) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Password security: LENGTH > complexity (14+ is better); password manager (generates strong, stores encrypted); passwordless (FIDO2/YubiKey, biometrics, Magic link) = the future; NIST: no forced rotation (encourages weak passwords).

High-Yield Core Concepts Tested on Exam

- Length > complexity (14 simple chars > 8 complex)
- FIDO2/YubiKey = passwordless: physical key that cannot be phished
- Password managers generate and store strong passwords securely
- NIST 800-63B: no forced periodic password changes
- Magic link: passwordless authentication via email link

Exam Tips & Classic Scenarios

- 'length over complexity' = NIST 800-63B guidance
- 'no forced password expiration' = NIST recommendation
- 'phishing-resistant MFA' = FIDO2/YubiKey

Typical Exam Scenario: 'a 16-character simple password is better than a 10-character complex one' = NIST guidance.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.6 — Password Security)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **FIDO2:** Open standard for passwordless authentication utilizing public key cryptography and hardware security keys/platform biometrics (WebAuthn).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. MFA combines factors from different categories. Which trio represents the 3 categories?

- A) Password, PIN, and secret answer
- B) Something you know, something you have, something you are
- C) 3 different passwords
- D) Username, password, and email

2. MFA requires at least two authentication factors. Which combination represents genuine multi-factor authentication?

- A) Password + PIN
- B) Password + Physical token
- C) Two types of biometrics
- D) Security question + Password

3. The correct way to STORE user passwords:

- A)** Hash with salt (e.g., bcrypt)
- B)** Reversible AES encryption
- C)** Plaintext protected by firewall
- D)** Base64

4. Corporate scenario (Password Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'Length > complexity (14 simple chars > 8 complex)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Length > complexity (14 simple chars > 8 complex)...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Password Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'FIDO2/YubiKey = passwordless: the physical key that cannot be phished'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: FIDO2/YubiKey = passwordless: the physical key that cannot be phished...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Password Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: '"length over complexity'=NIST 800-63B guidance'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'length over complexity'=NIST 800-63B guidance...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Password Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'a 16-character simple password is better than a 10-character complex one'=NIST guidance.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'a 16-character simple password is better than a 10-character complex one'=NIST guidance....

8. Corporate scenario (Password Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'Length > complexity (14 simple chars > 8 complex)'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Length > complexity (14 simple chars > 8 complex).
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Password Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'FIDO2/YubiKey = passwordless: the physical key that cannot be phished'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: FIDO2/YubiKey = passwordless: the physical key that cannot be phished...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Password Security): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.6), an analyst evaluates the following technical requirement: 'length over complexity'=NIST 800-63B guidance'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'length over complexity'=NIST 800-63B guidance...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Something you know, something you have, something you are.

✓ **Why it's correct:** Multi-factor authentication (MFA) requires combining at least two factors from distinct categories. The three classic categories are: something you know (knowledge, such as a password or PIN), something you have (possession, such as a physical token or code-generating app), and something you are (inherence, such as a fingerprint or facial recognition). The option 'Something you know, something you have, something you are' is the only one that correctly lists these three categories, as defined by NIST SP 800-63 and CompTIA Security+ SY0-701. MFA is an access control that mitigates credential compromise risks, as an attacker would need to overcome multiple independent barriers.

✗ **Why the others are wrong:**

- *Password, PIN, and secret answer:* Password, PIN, and secret answer are all examples of 'something you know' (knowledge factor). Although they are authentication mechanisms, they belong to the same category, so they do not constitute true MFA. Using multiple secrets of the same type is called multi-step authentication or apparent multifactor, but it does not meet the requirement of distinct categories. Additionally, secret answers are often vulnerable to social engineering attacks and can be discovered, not offering the same level of security as a second factor from a different category.
- *3 different passwords:* Three different passwords are still only a knowledge factor. Repeating passwords does not add a new authentication category; it only increases complexity within the same category. This is not MFA, because an attacker who compromises the password capture mechanism (e.g., keylogger or phishing) can obtain all three. Security is not multiplied by the number of passwords, but by the diversity of factors. CompTIA Security+ emphasizes that MFA requires factors of different types, not multiple instances of the same type.
- *Username, password, and email:* Username and email are identifiers, not authentication factors. The username and email address are public or easily discovered and do not prove identity. The password is a knowledge factor, but the other two are not authentication factors. Therefore, this combination does not represent MFA. Additionally, email can be used as a channel for sending codes, but by itself it is not a factor; it is a transport medium. The formal definition of MFA requires each factor to be from a different category (knowledge, possession, inherence), and here there is only one real factor.

2) B — Password + Physical token.

✓ **Why it is correct:** The combination ****Password + Physical token**** represents genuine multi-factor authentication because it combines two distinct factors: something you know (the password) and something you have (the physical token, such as a smart card, USB key, or OTP generator device). MFA requires combining at least two of the three classic factors: knowledge (something you know), possession (something you have), and inherence (something you are). In the CompTIA Security+ (SY0-701) syllabus, this distinction is fundamental to avoid false MFA, such as password + PIN, which are both from the same factor (knowledge).

✗ **Why the others are wrong:**

- *Password + PIN:* Password and PIN are both based on knowledge; that is, they represent the same authentication factor (something you know). Even if they are two different secrets, they do not constitute genuine MFA, as there is no combination of distinct factors. An attacker who obtains both (e.g., via keylogger or social engineering) compromises authentication. To be MFA, it is necessary to add a possession or inherence factor. Therefore, this option is incorrect.
- *Two types of biometrics:* Two types of biometrics (e.g., fingerprint and facial recognition) belong

to the same factor: inherence (something you are). Although they are distinct methods, they do not constitute genuine MFA, as they do not combine different factors. MFA requires combining distinct categories (knowledge, possession, inherence). Additionally, biometrics can be problematic if compromised (once leaked, they cannot be changed). Thus, this option does not meet the multi-factor requirement.

- *Security question + Password*: Security questions and passwords are both based on knowledge (something you know). The security question is often used as a second step, but it still belongs to the same factor. Therefore, it is not genuine MFA. Furthermore, security questions are vulnerable to social engineering attacks and can be discovered on social media. To be MFA, it would be necessary to add a possession or inherence factor. Thus, this combination is incorrect.

3) A — Hash with salt (e.g., bcrypt).

✓ **Why it is correct:** Secure storage of user passwords requires the use of slow cryptographic hash functions resistant to brute-force attacks, such as bcrypt, scrypt, or Argon2, combined with a unique random salt per user. The salt prevents precomputed table attacks (rainbow tables) and ensures that identical passwords produce different hashes. Functions like bcrypt are designed to be computationally expensive, adjustable by cost factor, making dictionary and offline brute-force attacks difficult. The hash is one-way, so even if the database is compromised, the attacker does not directly obtain the original password, only the hash, which must be cracked individually.

✗ **Why the others are wrong:**

- *Reversible AES encryption*: AES is a reversible symmetric cipher: with the correct key, the ciphertext can be decrypted back to plaintext. If passwords are stored encrypted with AES, anyone who obtains the encryption key (e.g., through compromise of the application server or database) can recover all original passwords. This violates the principle that not even system administrators should know user passwords. Additionally, AES key management adds unnecessary complexity and risk for data that never needs to be recovered in plaintext.

- *Plaintext protected by firewall*: Storing passwords in plaintext means they are readable in the database or configuration file. A firewall protects against unauthorized network access but does not prevent an attacker who exploits an application vulnerability, a malicious insider, or an administrator with database access from directly reading the passwords. Defense in depth requires that sensitive data be protected at rest, regardless of perimeter controls. A firewall is a network control, not a credential storage control.

- *Base64*: Base64 is a reversible encoding without a key, often used to represent binary data in text. It offers no confidentiality: anyone can decode a Base64 string instantly. Storing passwords in Base64 is functionally equivalent to storing them in plaintext, just with an obfuscated appearance. There is no salt, no computational cost, and no resistance to attacks. It is a completely inadequate practice for credential protection.

4) A — Implement the corresponding solution: Length > complexity (14 simple chars > 8 complex)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Password Security): Length > complexity (14 simple chars > 8 complex). Longer passwords exponentially increase the search space for brute-force attacks. For example, a 14-character password with only lowercase letters has $26^{14} \approx 2^{65.8}$ possible combinations, while an 8-character password with mixed case, digits, and symbols has about $94^8 \approx 2^{52.4}$ combinations. Thus, length is more effective than complexity. Modern guidelines (NIST SP 800-63B) recommend a minimum of 8 characters and encourage longer passphrases.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) A — Implement the corresponding solution: FIDO2/YubiKey = passwordless: the physical key that cannot be phished....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Password Security): FIDO2/YubiKey = passwordless: the physical key that cannot be phished. FIDO2 is an open authentication standard that uses public-key cryptography, where the private key never leaves the hardware authenticator (e.g., YubiKey). This prevents phishing because the authenticator verifies the origin (domain) and will not release credentials to a fake site. It also eliminates shared secrets (passwords) that can be stolen.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: 'length over complexity'=NIST 800-63B guidance....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Password Security): 'length over complexity'=NIST 800-63B guidance. NIST Special Publication 800-63B recommends prioritizing password length over complexity requirements, as longer passwords are generally more resistant to brute-force attacks and easier for users to remember. The appropriate action is to implement the corresponding solution, which includes enforcing minimum length (e.g., 8 characters) and checking against breached password lists.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'a 16-character simple password is better than a 10-character complex one'=NIST guidance.....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Password Security): 'a 16-character simple password is better than a 10-character complex one'=NIST guidance..

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

8) A — Implement the corresponding solution: Length > complexity (14 simple chars > 8 complex)..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Password Security): Length > complexity (14 simple chars > 8 complex). Longer passwords increase entropy and resistance to brute-force attacks more effectively than short complex ones. NIST guidelines recommend length over complexity and checking against breached password lists.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: FIDO2/YubiKey = passwordless: the physical key that cannot be phished....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Password Security): FIDO2/YubiKey = passwordless: the physical key that cannot be phished. FIDO2 uses public-key cryptography bound to the origin, so credentials cannot be replayed on a phishing site, making it phishing-resistant.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: 'length over complexity'=NIST 800-63B guidance....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.6 (Password Security): 'length over complexity'=NIST 800-63B guidance. NIST Special Publication 800-63B recommends prioritizing password length over complexity requirements, as longer passwords are generally more resistant to brute-force attacks and easier for users to remember. This guidance also discourages forced periodic password changes without cause.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting principle and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.